

CHALLENGE #6: Old Sessions Write-up.

Old Sessions

Easy

Web Exploitation

picoCTF 2026

AUTHOR: DAVID GAVIRIA

Description

Proper session timeout controls are critical for securing user accounts. If a user logs in on a public or shared computer but doesn't explicitly log out (instead simply closing the browser tab), and session expiration dates are misconfigured, the session may remain active indefinitely.

This then allows an attacker using the same browser later to access the user's account without needing credentials, exploiting the fact that sessions never expire and remain authenticated.

Additional details will be available after launching your challenge instance.

4,212 users solved

picoCTF{FLAG}

Submit Flag

This challenge launches an instance on demand.

Its current status is: NOT_RUNNING

Launch Instance

Hints

1

2

Do you know how to use the web inspector?

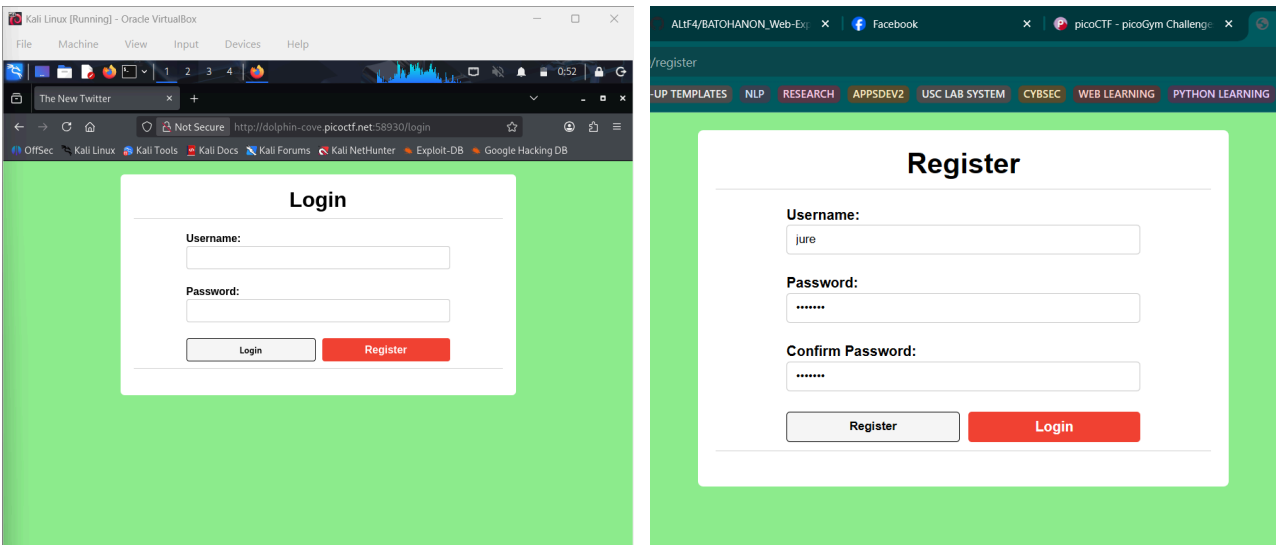
Hints

1

2

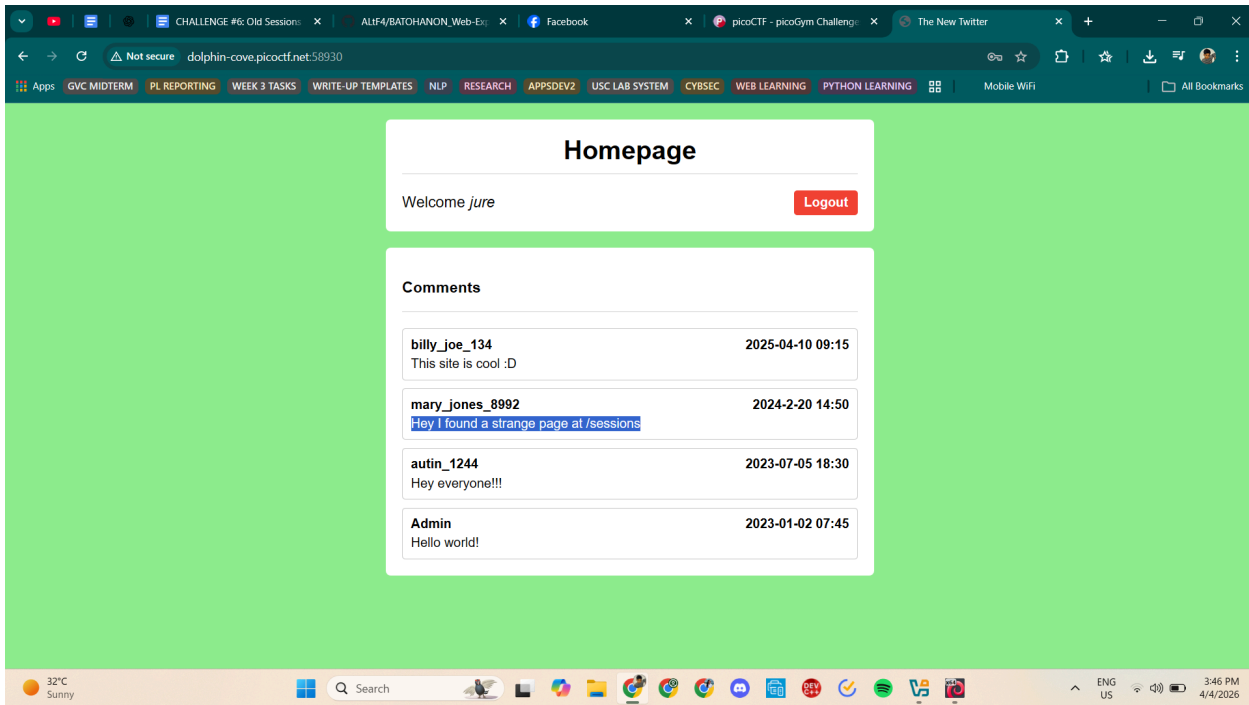
Where are cookies stored?

Solving Process:

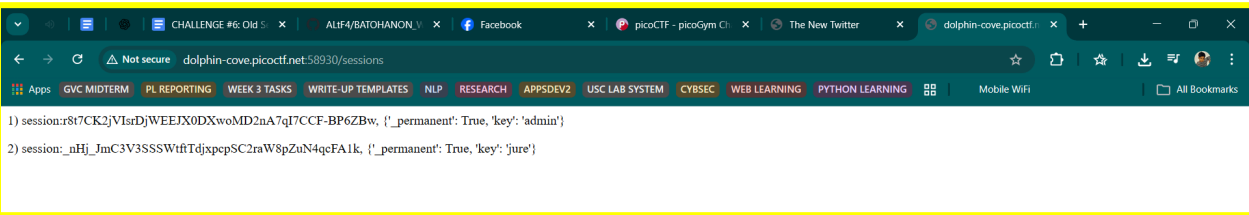
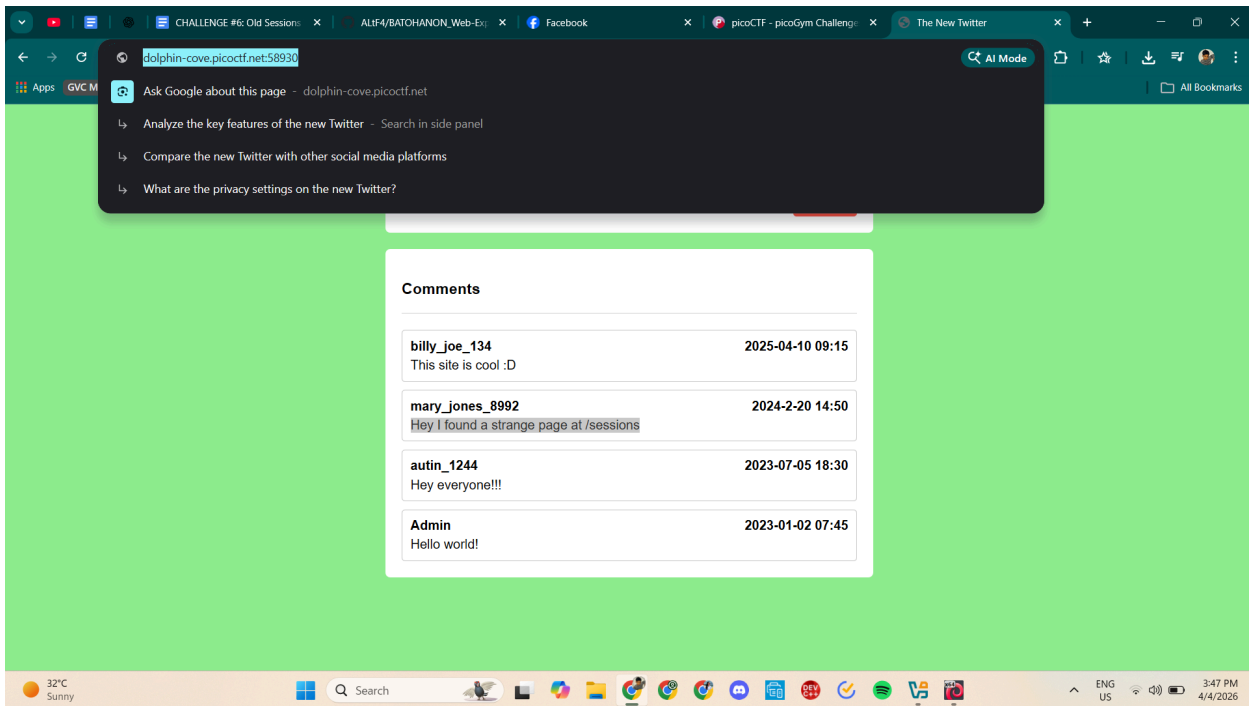


Upon visiting the page, the site appeared as a simple social media platform with a standard landing page. To begin exploring the application, a new user account was registered and used to log in.

After logging in successfully, the dashboard page appeared, displaying a message that mentioned a strange page located at the /sessions endpoint.

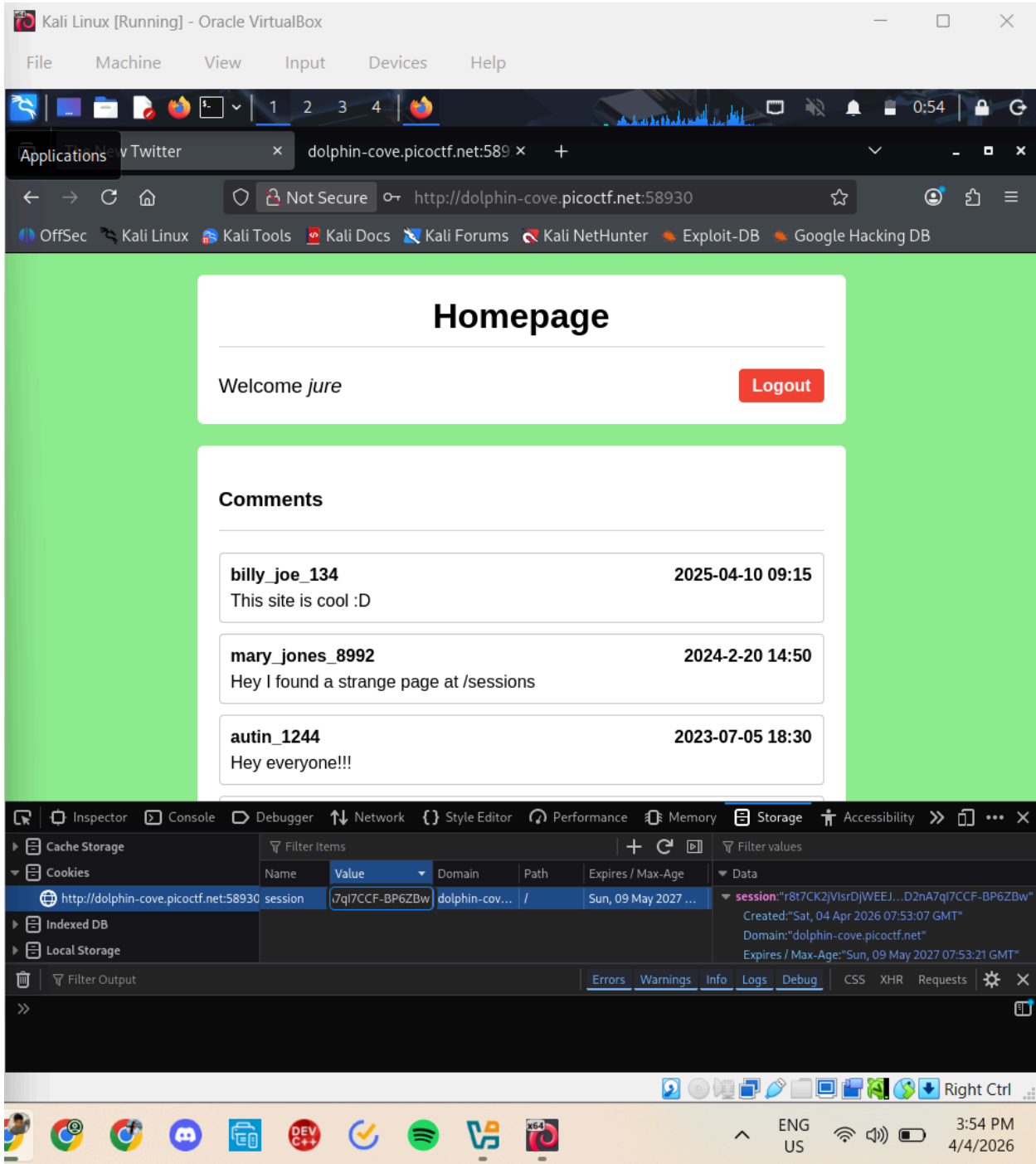


To investigate further, the URL was modified by adding `/sessions` at the end of the website address. Navigating to this endpoint revealed a page that displayed a plaintext list of active session keys currently stored on the server. Among the listed session identifiers was the session belonging to the admin user.

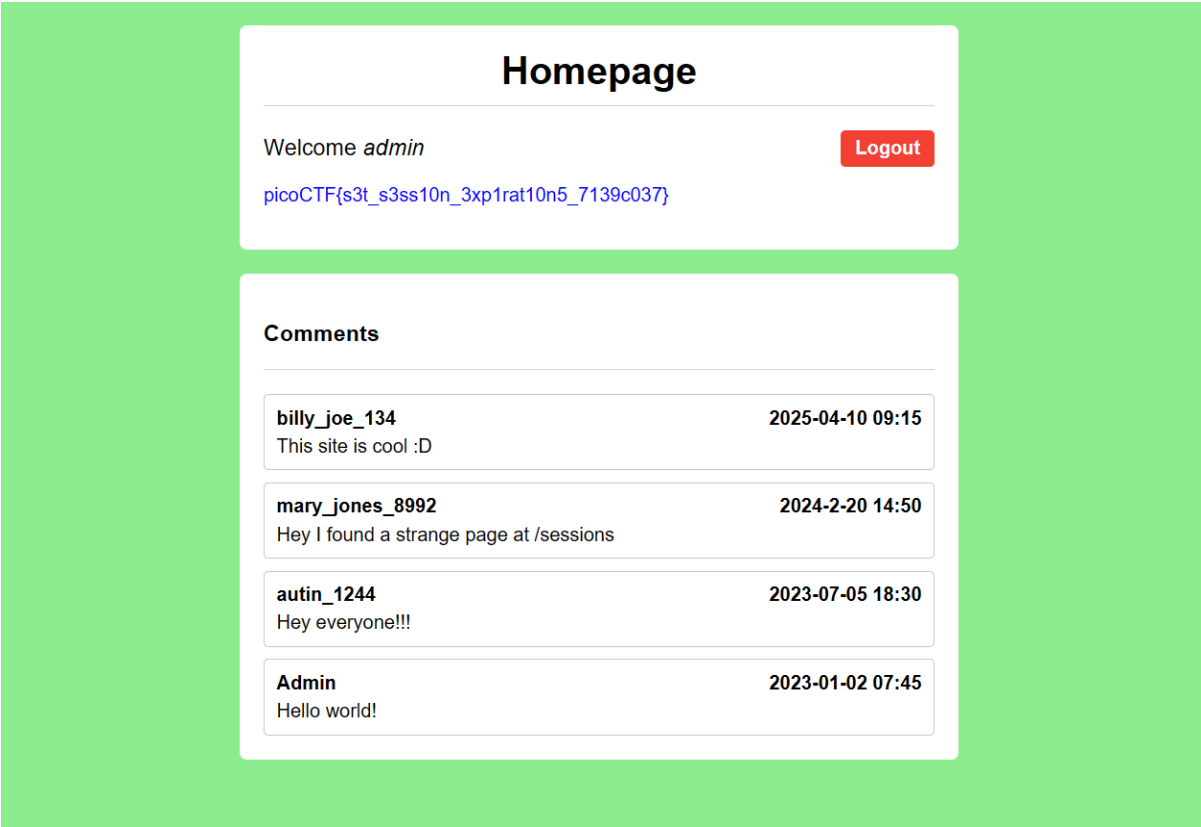


This behavior indicated a vulnerability in the application. The website was exposing sensitive session information through a publicly accessible endpoint. Because the developer configured the session as permanent and did not implement a proper session expiration mechanism, any user who obtains a valid session identifier can impersonate the associated account. This situation creates a **session hijacking vulnerability**, where an attacker can reuse another user's session token to gain unauthorized access.

To exploit this vulnerability, the session string associated with the **admin account** was copied from the list displayed on the /sessions page. After copying the session value, the main page of the challenge was opened again. Inside the developer tools, the **Storage** tab was opened to locate the stored cookies for the website. Within the cookies list, a cookie named **session** was found, which contained the current user's session ID. The value of this cookie was edited by replacing the existing session ID with the **admin session string** that was copied earlier.



After inserting the admin session value, the page was refreshed. Because the browser was now sending the admin's session token to the server, the application recognized the user as the administrator. As a result, the page updated and displayed the message "Welcome admin" along with the flag, confirming that the session hijacking attack was successful.



Old Sessions

Easy Web Exploitation picoCTF 2026

AUTHOR: DAVID GAVIRIA

Description

Proper session timeout controls are critical for securing user accounts. If a user logs in on a public or shared computer but doesn't explicitly log out (instead simply closing the browser tab), and session expiration dates are misconfigured, the session may remain active indefinitely. This then allows an attacker using the same browser later to access the user's account without needing credentials, exploiting the fact that sessions never expire and remain authenticated. Your friend tells you to check out a new social media platform he built a few years ago. Although its still under development, he said the site is almost complete. He also mentioned that he hates constantly logging into sites, and so has made his page that 'once you login, you never have to log-out again!' Browse [here](#), and find the flag!

This challenge launches an instance on demand.

Its current status is: RUNNING

Instance Time Remaining: 14:50

Restart Instance

Hints

1 2

4,217 users solved

92% Liked

picoCTF{s3t_s3ss10n_3xp1rat10n5_7139c037}

Submit Flag

Hurray! You solved this challenge.

Reflection:

This challenge helped me understand how improper session management can lead to session hijacking attacks. By exposing active session IDs and not implementing session expiration, the application allowed unauthorized users to impersonate other accounts, including the administrator. The activity emphasized the importance of secure session handling, proper access controls, and implementing session timeouts to prevent attackers from taking over user accounts.